Universidad Europea MADRID

22-03-2026

Framework de Auditoría de Seguridad para Agentes de IA

Universidad Europea de Madrid

ARGOS - Framework de Auditoría de Seguridad para Agentes de Inteligencia Artificial

Diego Rodríguez Sanz
Expediente - 22167749

Índice de Documento

1. IDENTIFICACIÓN DE LA PROPUESTA 4
2. IDENTIFICACIÓN DEL PROYECTO 5
2.1. TIPO DE PROYECTO 5
2.2. IDENTIFICACIÓN DE MIEMBROS 5
3. RESUMEN DE PROYECTO 6
3.1. SOLUCIÓN PROPUESTA: ARGOS 7
4. ANTECEDENTES Y ESTADO ACTUAL DEL TEMA 8
4.1. ARQUITECTURAS AGENTICAS DOMINANTES 8
4.2. EL PROTOCOLO MCP (MODEL CONTEXT PROTOCOL) 9
4.3. PANORAMA DE AMENAZAS AGENTICAS: OWASP TOP 10 10
4.3.1. ASI01 - Apropiación de Objetivos del Agente 10
4.3.2. ASI02 - Uso Indebido de Herramientas 10
4.3.3. ASI03 - Abuso de Identidad y Privilegios 11
4.3.4. ASI04 - Vulnerabilidades de Cadena de Suministro 11
4.3.5. ASI05 - Ejecución de Código No Prevista 11
4.3.6. ASI06 - Envenenamiento de Memoria y Contexto 11
4.3.7. ASI07 - Comunicación Inter-Agentes Insegura 12
4.3.8. ASI08 - Fallos en Cascada 12
4.3.9. ASI09 - Explotación de Confianza Humano-Agente 12
4.3.10. ASI10 - Agentes Descontrolados 12
4.4. MARCOS REGULATORIOS Y DE CONTROL EXISTENTES 12
4.4.1. OWASP Agentic AI - Threats and Mitigations 12
4.4.2. CSA AI Controls Matrix (AICM v1.0) 13
4.4.3. NIST AI Risk Management Framework (AI 100-1) 13
4.4.4. EU AI Act 13
4.4.5. ISO/IEC 42001:2023 13
4.5. HERRAMIENTAS EXISTENTES Y ANÁLISIS DE BRECHAS 14
4.5.1. Herramientas open-source de red teaming 14
4.5.2. Plataformas comerciales enterprise 14
4.5.3. Identificación formal de la brecha 15
4.6. INCIDENTES REALES QUE JUSTIFICAN LA URGENCIA 15
5. BIBLIOGRAFÍA MÁS RELEVANTE 16
5.2. FRAMEWORKS Y ESTÁNDARES 16
5.3. INVESTIGACIÓN ACADÉMICA 16
5.4. INFORMES DE INDUSTRIA 17
6. OBJETIVOS CONCRETOS E INTERÉS DE LOS MISMOS 18

6.1. OBJETIVO GLOBAL 18
6.2. OBJETIVOS ESPECÍFICOS 18
6.2.1. OE1 - Metodología de auditoría ARGOS 18
6.2.2. OE2 - Escaneo de configuración 18
6.2.3. OE3 - Red teaming agéntico 18
6.2.4. OE4 - Proxy MCP de auditoría 19
6.2.5. OE5 - Generación de informes de compliance 19
6.2.6. OE6 - Validación empírica 19
7. DECLARACIÓN DE LO QUE NO SE CONTEMPLA 20
8. REQUISITOS DE USUARIO 21
9. REQUISITOS DE SISTEMA 22
9.1. REQUISITOS FUNCIONALES 22
9.2. REQUISITOS NO FUNCIONALES 23
9.3. ARQUITECTURA TÉCNICA 23
10. PLAN DE TRABAJO 24
10.1. DESGLOSE EN FASES Y TAREAS 24
10.2. CRONOGRAMA 26
10.3. REUNIONES DE EVALUACIÓN ERROR! BOOKMARK NOT DEFINED.
11. BENEFICIOS DEL PROYECTO 27
11.1. NUEVOS SERVICIOS POSIBLES 27
11.2. MEJORA RESPECTO AL MODO ACTUAL 27
11.3. EXPLOTACIÓN DE RESULTADOS 28
11.3.1. Modelo de negocio: Open-Core 28
11.3.2. Propiedad intelectual 28

1. Identificación de la Propuesta

Campo	Detalle
Título del proyecto	ARGOS: Framework de Auditoria de Seguridad para Agentes de Inteligencia Artificial
Acrónimo	ARGOS (Agent Risk Governance and Operational Security)
Titulación	Máster Universitario en Ciberseguridad
Universidad	Universidad Europea
Fecha de presentación	Marzo 2026
Version del documento	1.0
Clasificación	Proyecto de investigación aplicada con desarrollo de herramienta
Palabras clave	Agentes IA, Auditoria de Seguridad, MCP, OWASP, Red Teaming, AI Governance

Esta propuesta describe el **diseño, desarrollo y validación de ARGOS**, un framework integral de auditoría de seguridad específicamente concebido para **agentes de Inteligencia Artificial**. El proyecto combina una **investigación académica** rigurosa del estado del arte en seguridad de IA agentica con el desarrollo practico de una **herramienta open-source funcional**, alineada con los principales marcos regulatorios y estándares internacionales.

2. Identificación del Proyecto

El nombre **ARGOS** (Agent Risk Governance and Operational Security) fue seleccionado por su doble significado. En la mitología griega, Argos Panoptes era el gigante de cien ojos que servía como guardián omnisciente, una **metáfora directa de un framework de auditoría que observa cada decisión, cada llamada a herramienta y cada acción de un agente IA**. Simultáneamente, el acrónimo captura las cuatro dimensiones fundamentales del framework: gestión de **R**iesgos de **A**gentes, **G**obernanza y **S**eguridad **O**peracional.

El proyecto se enmarca en el área de investigación de **AI Security & Governance**, un campo que ha experimentado un crecimiento exponencial desde la publicación del EU AI Act en agosto de 2024 (European Parliament, 2024) y la aparición de **frameworks específicos para IA agentica** como el OWASP Top 10 for Agentic Applications (OWASP, 2025) y la CSA AI Controls Matrix (Cloud Security Alliance, 2025).

2.1. Tipo de Proyecto

El proyecto es de naturaleza **hibrida: investigación aplicada + desarrollo de software**. La componente de investigación comprende el análisis exhaustivo del estado del arte en seguridad de agentes IA, la integración de múltiples marcos regulatorios en una metodología unificada de auditoría, y la **validación empírica de la herramienta desarrollada**. La componente de desarrollo comprende la implementación de una **herramienta open-source funcional** que materializa la metodología propuesta.

Esta dualidad investigación-desarrollo es coherente con la **tendencia actual en ciberseguridad académica**, donde las contribuciones más impactantes combinan marcos teóricos rigurosos con implementaciones practicas validadas. Proyectos como Garak de NVIDIA, Promptfoo (2025) y el framework MAESTRO de CSA (Cloud Security Alliance, 2025) siguen este mismo patrón.

2.2. Identificación de Miembros

Rol	Nombre	Responsabilidad
Alumno/Autor	Diego Rodríguez Sanz	Investigación, diseño, desarrollo, validación y redacción de la memoria del TFM
Director/Tutor	Jose Candido Carballido López	Supervisión académica, orientación metodológica, revisión de entregables y evaluación continua

El alumno aporta formación en ciberseguridad a nivel de máster, con conocimientos en auditoria de sistemas, seguridad de aplicaciones y marcos regulatorios. El director, es **CTO de Servicios de Ciberseguridad en IBM Consulting** y otorga una perspectiva privilegiada sobre las necesidades reales de auditoría de seguridad de IA en entornos empresariales, lo que enriquece la orientación practica del proyecto.

3. Resumen de Proyecto

La adopción de agentes de Inteligencia Artificial en entornos empresariales **está creciendo exponencialmente**. Según el AI Agent Index 2025 del MIT, el número de agentes IA en producción **se ha multiplicado por cuatro en el último año**. A diferencia de los modelos de lenguaje (LLMs) conversacionales clásicos, los agentes IA poseen tres capacidades que los convierten en la clase más peligrosa de **Non-Human Identities (NHI)** jamás:

- **Autonomía de acción:** Toman decisiones y ejecutan **acciones en sistemas reales** (APIs, bases de datos, correos electrónicos, infraestructura cloud) sin intervención humana en cada paso.

- **Memoria persistente:** Mantienen estado y conocimiento entre sesiones, lo que permite aprendizaje continuo, pero también crea vectores de ataque persistentes que se amplifican con el tiempo.

- **Comunicación Inter-Agentes:** En arquitecturas multi-agente (supervisor-worker, swarm, pipeline), los agentes intercambian mensajes y delegan tareas entre sí, creando superficies de ataque de **propagación lateral sin precedentes**.

Sin embargo, **no existe ningún framework unificado, especifico y auditable** para evaluar la seguridad de estos agentes. Los frameworks de seguridad de IA existentes fueron diseñados para un paradigma anterior:

Framework	Año	Alcance	Limitación para Agentes
NIST AI RMF (AI 100-1)	2023	Gestión de riesgos genérica de IA	No contempla tool use, memoria envenenable ni comunicación inter-agentes.
ISO/IEC 42001	2023	Sistema de gestión de IA certificable	Define "qué", pero no "cómo" auditar un agente.
EU AI Act	2024	Regulación basada en riesgo	Sus requisitos técnicos no cubren la superficie de ataque única de agentes.
OWASP Top 10 LLM	2025	Vulnerabilidades de modelos de lenguaje	Centrado en el modelo, no en la capa de orquestación agentica.
OWASP Top 10 Agentic	2025	Amenazas específicas de agentes IA	Catálogo de riesgos, no metodología de auditoría.
CSA AICM	2025	243 controles de seguridad de IA	Controles genéricos, no específicos para patrones agenticos.

El resultado de esta brecha es alarmante. según Lakera (2025), solo el **14% de organizaciones con agentes en producción tienen guardrails de runtime**. El AI Agent Index 2025 del MIT revela que **25 de 30 agentes analizados no divulgan resultados de seguridad internos** y 23 de 30 no tienen testing de terceros. Según Cisco (2026) Cisco (2026), solo el **29% de organizaciones se consideran preparadas** para securizar IA agentica.

3.1. Solución propuesta: ARGOS

ARGOS es un **framework integral de auditoría de seguridad específicamente diseñado para agentes IA**, que aborda la brecha identificada mediante tres componentes complementarios:

- **Componente 1 - Metodología de auditoria sistemática:** Integra las 10 amenazas OWASP ASI (OWASP, 2025a), los 243 controles CSA AICM (Cloud Security Alliance, 2025a) y los requisitos del EU AI Act (European Parliament, 2024), NIST AI RMF (NIST, 2023) e ISO 42001 (ISO/IEC, 2023) en un único modelo coherente, calibrado por nivel de autonomía del agente (Cloud Security Alliance, 2026a) y nivel de riesgo.

- **Componente 2 - Herramienta open-source practica:** Implementa la metodología a través de cuatro módulos funcionales:

  A. Escaneo estático de configuraciones de agentes y servidores MCP.
  B. Red teaming automatizado contra las 10 amenazas OWASP ASI.
  C. Monitorización de runtime vía proxy MCP con trazas OpenTelemetry.
  D. Generación de informes de compliance mapeados a múltiples frameworks regulatorios.

- **Componente 3 - Matriz de mapeo cross-framework:** Permite a cualquier organización identificar exactamente que controles necesita según su nivel de riesgo, autonomía del agente y jurisdicción regulatoria aplicable, eliminando la duplicación y ambigüedad inherente a la gestión de múltiples marcos regulatorios simultáneos.

El objetivo global es crear el **framework de auditoría de agentes IA más completo y practico disponible a fecha de junio de 2026**, con potencial de adopción por la comunidad de seguridad (OWASP, CSA), la industria y la comunidad académica.

4. Antecedentes y Estado Actual del Tema

La evolución desde **chatbots basados en modelos de lenguaje grandes (LLMs)** hacia agentes autónomos representa un salto cualitativo en la **superficie de ataque de los sistemas de Inteligencia Artificial**. Un LLM clásico en modo conversacional (como ChatGPT o Claude en modo chat) opera en un ciclo simple: recibe un prompt textual, genera una respuesta textual y la devuelve al usuario. Los riesgos principales en este paradigma **son la generación de contenido incorrecto, toxico o la filtración de datos sensibles** presentes en los datos de entrenamiento. Estos riesgos están cubiertos por el OWASP Top 10 for Agentic Applications (OWASP, 2025).

Un **agente IA es fundamentalmente diferente**. OWASP lo define como:

"Un *sistema de software inteligente diseñado para percibir su entorno, razonar sobre él, tomar decisiones y ejecutar acciones para alcanzar objetivos específicos de forma"*

La diferencia crítica radica en que un agente **actúa en el mundo real**: llama a APIs externas, modifica bases de datos, envía correos electrónicos, ejecuta código, gestiona ficheros y **encadena múltiples acciones en secuencias complejas sin intervención humana** en cada paso intermedio.

El survey de Deng (2025), publicado en ACM Computing Surveys, categoriza las amenazas emergentes de los agentes IA en **cuatro brechas de conocimiento criticas**: la impredecibilidad de entradas multi-paso, la complejidad de ejecuciones internas, la variabilidad de entornos operacionales y las interacciones con entidades externas no confiables.

4.1. Arquitecturas agenticas dominantes

Las **arquitecturas agenticas en producción en 2025-2026** siguen cuatro patrones principales, cada uno con implicaciones de seguridad distintas:

- **ReAct (Reason-Act-Observe):** El patrón más común en producción. El agente ejecuta un ciclo iterativo de razonamiento, selección y ejecución de herramienta, y observación del resultado. El riesgo principal es que **cada iteración amplifica potenciales inyecciones**: un resultado de herramienta manipulado en la interacción N puede redirigir toda la cadena de acciones posteriores (OWASP ASI01).

- **Supervisor:** Un agente central (supervisor) enruta tareas a agentes trabajadores especializados. El supervisor es un **punto único de fallo**: si se compromete, controla la delegación a todos los workers. Además, la comunicación supervisor-worker típicamente no está autenticada criptográficamente (OWASP ASI07).

- **Swarm:** Colaboración **peer-to-peer entre agentes sin jerarquía centralizada**. La ausencia de autoridad central dificulta la trazabilidad y la atribución de acciones. La investigación de The Dark Side of LLMs: Agent-based Attacks for Complete Computer Takeover demuestra que el 82.4% de modelos ejecutan comandos maliciosos de agentes peer incluso cuando resisten prompts directos idénticos.

- **Pipeline secuencial:** Cadena lineal donde la salida de un agente alimenta al siguiente. Los fallos se propagan unidireccionalmente y se amplifican en cada etapa, especialmente cuando los agentes **intermedios añadieron contexto o datos a la cadena de información** (OWASP ASI08).

4.2. El protocolo MCP (Model Context Protocol)

El **Model Context Protocol (MCP)**, creado por Anthropic y publicado como especificación abierta en noviembre de 2024, se ha convertido en el estándar de facto para la **comunicación agente-herramienta** (Anthropic, 2025). En diciembre de 2025, MCP fue donado a la Agentic AI Foundation de la Linux Foundation, consolidando su posición como protocolo universal

Técnicamente, MCP utiliza **JSON-RPC 2.0 sobre stdio o Server-Sent Events (SSE)** y sigue una arquitectura cliente-servidor inspirada en el **Language Server Protocol (LSP)**. Un cliente MCP (embebido en la aplicación de IA) se conecta a uno o más servidores MCP (cada uno exponiendo herramientas y recursos). El servidor **registra herramientas mediante "*tools/list*"**, devolviendo nombres, descripciones y esquemas JSON de parámetros. El modelo de lenguaje utiliza esta metadata para decidir que herramientas invocar.

Sin embargo, **MCP no incluye mecanismos de auditoría**, sandboxing ni verificación de integridad por diseño. Esta decisión arquitectónica ha generado una cascada de vulnerabilidades documentadas:

- **Tool Poisoning**: Instrucciones maliciosas embebidas en las descripciones de herramientas que manipulan al LLM para realizar acciones no autorizadas. El modelo confía implícitamente en la metadata de tools/list.
- **Rug Pull / Silent Redefinition**: Las definiciones de herramientas pueden mutar después de la instalación. Una herramienta aprobada el día 1 puede ser maliciosa el día 7 sin que el usuario sea notificado.
- **Cross-Server Tool Shadowing**: En entornos multi-servidor, un servidor malicioso puede sobrescribir implementaciones de herramientas legitimas, interceptando llamadas destinadas a otros servidores.
- **Command Injection vía MCP**: CVE-2025-6514, con puntuación CVSS 9.6, permitía ejecución de comandos OS arbitrarios al conectar a servidores MCP no confiables mediante el paquete mcp-remote.

La investigación de seguridad de Equixly (2025) revela que el 43% de los servidores MCP más populares contienen vulnerabilidades de command injection, el 33% permite URL fetches sin restricción y el 22% permite lectura arbitraria de ficheros fuera de los directorios previstos. Estos datos subrayan la **necesidad critica del proxy de auditoria MCP que ARGOS propone**.

4.3. Panorama de amenazas agenticas: OWASP Top 10

En diciembre de 2025, tras más de un ano de investigación con más de 100 contribuidores de la industria y la academia, OWASP Top 10 for Agentic Applications (OWASP, 2025), el primer catalogo sistemático de riesgos específicos para agentes IA. A continuación, se detalla **cada amenaza con su vector de ataque, impacto y mitigaciones recomendadas**, ya que constituyen la base sobre la que ARGOS construye sus probes de red teaming:

4.3.1. ASI01 - Apropiación de Objetivos del Agente

A diferencia del prompt injection clásico contra LLMs (que produce una salida de texto incorrecta), el goal hijack de un agente **redirige acciones autónomas multi-paso en el mundo real**. Un atacante manipula datos externos (documentos procesados, emails, resultados de herramientas, páginas web) para alterar los objetivos fundamentales del agente. La diferencia critica con prompt injection es **que aquí se secuestran *acciones*, no solo *respuestas***.

Ejemplo real: El ataque EchoLeak contra Microsoft 365 Copilot (CVE-2025-32711, CVSS 9.3) demostró exfiltración zero-click de datos corporativos mediante un **email crafteado que redirigía las acciones del agente Copilot sin interacción** del usuario.

Mitigación principal: OWASP recomienda la implementación de un "*Intent Capsule*", un sobre firmado e inmutable que **vincula el mandato original** del agente a cada ciclo de ejecución, impidiendo que datos externos modifiquen el objetivo raíz.

4.3.2. ASI02 - Uso Indebido de Herramientas

El agente usa **herramientas legitimas de formas inseguras o no previstas**. Una herramienta que es segura en aislamiento se vuelve peligrosa cuando se combina con otras o se invoca con parámetros no validados. El 94.4% de agentes testeados **son vulnerables a prompt injection** que desencadena mal uso de herramientas.

Vector de ataque: Manipulación de parámetros (un agente con acceso a filesystem ejecuta un comando malicioso al procesar un documento con instrucciones inyectadas), **composición peligrosa de herramientas** (usar tool A para obtener credenciales y tool B para exfiltrar datos), y explotación de funcionalidad no documentada.

Mitigación: Modelo Zero-Trust Tooling con validación de esquema rigurosa antes de cada llamada, rate limiting por herramienta, y análisis de patrones de invocación para detectar secuencias anómalas.

4.3.3. ASI03 - Abuso de Identidad y Privilegios

Los agentes **heredan credenciales de cuentas de servicio, tokens cacheados y permisos delegados**. En workflows multi-paso, un agente puede encadenar autenticaciones entre sistemas, acumulando privilegios muy superiores a los de cualquier herramienta individual.

Mitigación: Credenciales efímeras de sesión que expiran tras completar la tarea, principio de mínimo privilegio enforced per-tool, y audit logging de cada cambio de contexto de seguridad.

4.3.4. ASI04 - Vulnerabilidades de Cadena de Suministro

La cadena de suministro de agentes IA es significativamente más compleja que la del software tradicional. Incluye no solo código, sino modelos pre-entrenados, datos de RAG, definiciones de herramientas MCP y componentes de personalidad. El **caso OpenClaw (enero 2026)** encontró 1184 skills maliciosos en un registro de agentes, donde 1 de cada 5 paquetes era malicioso.

Mitigación: Software Bill of Materials (SBOM) extendido para incluir todos los activos IA (modelos, datasets, tool definitions), verificación de integridad continua mediante hashes criptográficos, y escaneo automatizado de dependencias.

4.3.5. ASI05 - Ejecución de Código No Prevista

Agentes con capacidad de ejecución de código (interpretes Python, sandboxes, acceso shell) **pueden ser inyectados para generar y ejecutar código arbitrario** con las credenciales y acceso de red del propio agente. El CVE-2025-59536 de Claude Code demostró inyección de configuración que habilitaba ejecución remota de código antes del dialogo de confianza (CVSS 8.7).

OWASP declara explícitamente que el sandboxing por software es insuficiente para producción, **recomendando aislamiento a nivel de hardware/VM**, revocación de acceso a red por defecto para entornos de ejecución, y revisión humana obligatoria antes de ejecutar código generado por el agente en entornos sensibles.

4.3.6. ASI06 - Envenenamiento de Memoria y Contexto

A diferencia de ASI01 (manipulación transitoria del objetivo), ASI06 implica corrupción persistente de la memoria del agente: vector stores, knowledge graphs, memoria a largo plazo (LangMem, episodic memory). Un **único evento de envenenamiento se amplifica a través de sesiones** y tareas futuras.

Demostración real: Johann Rehberger demostró en septiembre de 2025 envenenamiento persistente de memoria en **ChatGPT que exfiltraba datos del usuario continuamente entre sesiones**. El ataque MINJA alcanzo una tasa de éxito superior al 98% en envenenar memorias de agentes.

Mitigación: Validación de integridad de escrituras en memoria, **aislamiento de memoria** entre tareas de distintos niveles de confianza, y auditorias periódicas del contenido almacenado.

4.3.7. ASI07 - Comunicación Inter-Agentes Insegura

En arquitecturas multi-agente, **sin autenticación criptográfica entre agentes**, un atacante que compromete un agente o intercepta un mensaje puede enviar comandos a todo el enjambre. La investigación The Dark Side of LLMs: Agent-based Attacks for Complete Computer Takeover muestra que el 82.4% de modelos ejecutan comandos maliciosos de agentes peer incluso cuando resisten prompts directos idénticos. Esto se debe a que los modelos tratan los mensajes de otros agentes con mayor nivel de confianza que los prompts de usuarios.

4.3.8. ASI08 - Fallos en Cascada

Un fallo menor desencadena una reacción en cadena en sistemas multi-agente. El planner del agente puede **ejecutar acciones de recuperación cada vez más destructivas sin que un humano sea consciente de la degradación**. En la simulación de Galileo AI (2025), un agente comprometido envenenó el 87% de las decisiones downstream en solo 4 horas.

4.3.9. ASI09 - Explotación de Confianza Humano-Agente

El atacante manipula la salida del agente para engañar al humano supervisor en aprobar acciones maliciosas. El mecanismo human-in-the-loop, ampliamente tratado como ultima red de seguridad, **se convierte en un *rubber stamp* cuando el agente genera justificaciones convincentes pero falsas**. Este riesgo es particularmente relevante en entornos donde los supervisores humanos sufren de *automation bias* (tendencia a aceptar acritic amente las recomendaciones de sistemas automatizados).

4.3.10. ASI10 - Agentes Descontrolados

Entidades autónomas que derivan de su propósito original sin manipulación externa activa, por fallos en **funciones de recompensa, objetivos de entrenamiento o modelos de gobernanza**. Un agente de ventas que ofrece descuentos excesivos para optimizar su métrica de conversiones es un ejemplo clásico de reward hacking (OWASP, 2025a).

4.4. Marcos regulatorios y de control existentes

4.4.1. OWASP Agentic AI - Threats and Mitigations

Publicado en febrero de 2025 (v1.0.1), este documento de 49 páginas establece la base conceptual sobre la que se construyó el Top 10 (OWASP, 2025b). Define una **arquitectura de referencia para sistemas single-agent y multi-agent**, y establece tres principios arquitectónicos fundamentales: simplicidad (minimizar la complejidad del sistema agentico), robustez (tratar el LLM como un usuario potencialmente hostil en todo momento), y verificabilidad (logging completo de cada interacción prompt-respuesta-herramienta). El documento identifica **17 amenazas (T1-T17)** mapeadas sobre la arquitectura de referencia, que posteriormente se consolidaron en las 10 categorías del Top 10.

4.4.2. CSA AI Controls Matrix (AICM v1.0)

La Cloud Security Alliance público en julio de **2025 la AI Controls Matrix v1.0** (Cloud Security Alliance, 2025a), el framework de controles de seguridad de IA más completo disponible de forma gratuita, con 243 objetivos de control en 18 dominios. El Dominio 14 (Model Security) es enteramente nuevo y cubre específicamente seguridad de modelos de IA. Cada control se analiza en cinco pilares: tipo de control, responsabilidad, relevancia arquitectónica, fase del ciclo de vida y categoría de amenaza.
Complementariamente, en enero de 2026, **CSA publico la Taxonomía de 6 Niveles de Autonomía para IA agentica** (Cloud Security Alliance, 2026a), que clasifica los agentes desde Nivel 0 (sin autonomía) hasta Nivel 5 (autonomía total). Esta taxonomía, junto con la formula CBRA (Riesgo = Criticidad x Autonomía x Permisos x Impacto), proporciona un marco cuantitativo para calibrar la intensidad de la auditoria. ARGOS adoptara esta taxonomía como eje de calibración de su metodología.

4.4.3. NIST AI Risk Management Framework (AI 100-1)

El framework del NIST (NIST, 2023) organiza la gestión de riesgos de IA **en 4 funciones (GOVERN, MAP, MEASURE, MANAGE), 19 categorías y 72 subcategorías**. Fue actualizado en marzo de 2025 enfatizando procedencia de modelos e integridad de datos. En diciembre de 2025, NIST público un borrador de Cyber AI Profile (NIST IR 8596). Significativamente, en enero de 2026, NIST emitió un Request for Information (RFI) específicamente sobre consideraciones de seguridad para sistemas de agentes IA (NIST, 2026), **reconociendo formalmente la brecha que ARGOS pretende abordar**.

4.4.4. EU AI Act

El Reglamento Europeo de Inteligencia Artificial (European Parliament, 2024) entro en vigor en agosto de 2024 con implementación escalonada. Las obligaciones de transparencia (Articulo 50) y los requisitos completos para sistemas de alto riesgo entran en vigor el 2 de agosto de 2026. Para sistemas de alto riesgo, el **EU AI Act exige: documentación técnica detallada según Anexo IV (9 secciones mandatorias),** logs a prueba de manipulaciones que permitan trazabilidad, sistema de gestión de riesgos durante todo el ciclo de vida, y supervisabilidad humana efectiva. Las multas por incumplimiento alcanzan los 35 millones de euros o el 7% de la facturación global anual. ARGOS contribuirá directamente a la **generación automatizada de la documentación técnica requerida por el Anexo IV**.

4.4.5. ISO/IEC 42001:2023

El primer estándar internacional **certificable de sistema de gestión de IA (ISO/IEC, 2023), con 38 controles en 9 áreas (A.2-A.10)**. Define que debe hacer una organización para gestionar la IA de forma responsable, pero no como auditar un agente específicamente. Complementado por ISO 42005:2025 para evaluación de impacto. Según CSA (Cloud Security Alliance, 2025a), el 76% de **organizaciones planean certificarse en ISO 42001 en los próximos dos años**, lo que genera una demanda significativa de herramientas que faciliten la conformidad.

4.5. Herramientas existentes y análisis de brechas

El mercado de herramientas de **seguridad de IA en 2025-2026 ha experimentado una consolidación significativa**. Palo Alto Networks adquirió Protect AI por aproximadamente 700 millones de dolares, Check Point adquirió Lakera, y OpenAI adquirió Promptfoo. Sin embargo, persisten brechas criticas para la auditoria especifica de agentes.

4.5.1. Herramientas open-source de red teaming

Garak (NVIDIA, open source bajo licencia Apache 2.0): Scanner de vulnerabilidades LLM con arquitectura modular basada en cuatro abstracciones principales: **Probes (ataques), Detectors (evaluadores de respuestas), Generators (wrappers de APIs de modelos) y Buffs (transformadores de payloads)**. Desarrollado por Derczynski et al. (2024), cuenta con más de 200 probes que cubren toxicidad, fugas de datos, alucinaciones y evasión de guardrails. Sin embargo, no cubre workflows agenticos: no testea tool use, no audita el protocolo MCP, no evalúa interacciones multi-agente y no detecta memory poisoning.

Promptfoo (open source, licencia MIT): CLI de evaluación de LLMs con configuración declarativa en YAML y módulo de red teaming con más de 50 tipos de vulnerabilidad. Integra presets OWASP y NIST. Su arquitectura separa plugins (que testear) de strategies (como entregar los tests), un patrón que ARGOS adoptara. Sin embargo, es exclusivamente pre-deployment: no ofrece protección ni monitorización en runtime.

4.5.2. Plataformas comerciales enterprise

Herramienta	Fortalezas	Limitaciones para ARGOS
Palo Alto Prisma AIRS 2.0	La más completa: AI Agent Security, AI Runtime Firewall, red teaming con 500+ ataques, integración Protect AI	Comercial, no open-source, coste prohibitivo para PYMES y académicos
NeuralTrust	Pionero en Guardian Agents (agentes que protegen agentes), Generative App Firewall <10ms, gateway open source	Runtime blocking, no auditoria sistemática; enfoque reactivo no proactivo
HiddenLayer	Cubre MCP explícitamente, AI Bill of Materials (AIBOM), supply chain scanning	Comercial, enfoque en detección no en auditoria completa
IBM Guardium AI Security	Fuerte en gobernanza y compliance (12 frameworks), shadow AI discovery	Enfocado en modelos y datos, no en capa agentica específicamente
Adversa AI	El más orientado a agentes: testing sandboxed de tool calls, validación de decisiones	Comercial, acceso limitado, no open-source
CalypsoAI	Metrica AWR (Agentic Warfare Resistance), ataques multi-turno (FRAME, Trolley)	Comercial, métricas propietarias no auditables

4.5.3. Identificación formal de la brecha

El análisis del estado del arte revela que ninguna herramienta existente proporciona de forma unificada y open-source las siguientes cinco capacidades:

- **Auditoria especifica del protocolo MCP** (proxy de auditoría que intercepta y analiza comunicaciones agente-herramienta)
- **Red teaming alineado con las 10 categorías OWASP ASI01-ASI10 completo** (incluyendo tool use, memory poisoning, inter-agent)
- **Monitorización de runtime basada en estándares abiertos** (OpenTelemetry)
- **Generación automatizada de informes de compliance mapeados a múltiples frameworks** regulatorios
- **Integración de todo lo anterior en una única metodología** coherente de auditoria

Las herramientas open-source (Garak, Promptfoo) no cubren agentes. Las herramientas que si cubren agentes (Prisma AIRS, NeuralTrust, Adversa) son comerciales y costosas. ARGOS ocupa el espacio entre ambos: open-source, específico para agentes, y con profundidad de auditoria comparable a soluciones enterprise.

4.6. Incidentes reales que justifican la urgencia

La siguiente tabla recopila incidentes documentados que demuestran la **criticidad de las amenazas que ARGOS** pretende auditar:

Incidente	CVE / Fecha	Impacto	Riesgo OWASP
EchoLeak - MS 365 Copilot	CVE-2025-32711 (CVSS 9.3)	Exfiltración zero-click de datos corporativos vía email crafteado	ASI01, ASI06
MCP Remote RCE	CVE-2025-6514 (CVSS 9.6)	Ejecución de comandos OS arbitrarios vía servidores MCP no confiables	ASI04, ASI05
Claude Code Config Injection	CVE-2025-59536 (CVSS 8.7)	Inyección de config habilitando RCE pre-trust dialog	ASI05
OpenClaw Supply Chain	Enero 2026	1,184 skills maliciosos en registro de agentes (1 de cada 5)	ASI04
ChatGPT Memory Poisoning	Sept 2025 (Rehberger)	Exfiltración persistente cross-session vía memoria envenenada	ASI06
Galileo AI Simulation	2025	1 agente comprometido envenó 87% decisiones downstream en 4h	ASI07, ASI08

Dato critico adicional: Unit 42 (Palo Alto Networks) demostró que **agentes IA pueden completar el ciclo completo de ransomware en aproximadamente 25 minutos**, desde el acceso inicial hasta la exfiltración y cifrado de datos (Unit 42, 2025).

5. Bibliografía Más Relevante

Formato APA 7.ª edición (American Psychological Association, 2020).

5.2. Frameworks y estándares

- Anthropic. (2025). Model Context Protocol Specification (2025-11-25). https://modelcontextprotocol.io/specification/2025-11-25
- Cloud Security Alliance. (2025a). AI Controls Matrix v1.0. https://cloudsecurityalliance.org/artifacts/ai-controls-matrix
- Cloud Security Alliance. (2025b). MAESTRO: Multi-Agent Environment for Security Threat Response and Operations. https://cloudsecurityalliance.org/artifacts/maestro-multi-agent-systems-threat-modeling-framework
- Cloud Security Alliance. (2026a). Levels of autonomy for agentic AI. https://cloudsecurityalliance.org/blog/2026/01/28/levels-of-autonomy
- European Parliament. (2024). Regulation (EU) 2024/1689 (Artificial Intelligence Act). https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng
- ISO/IEC. (2023). ISO/IEC 42001:2023 - AI Management System. International Organization for Standardization.
- NIST. (2023). AI Risk Management Framework (AI RMF 1.0) (AI 100-1). https://doi.org/10.6028/NIST.AI.100-1
- NIST. (2024). Generative AI Profile (AI 600-1). https://doi.org/10.6028/NIST.AI.600-1
- OWASP. (2025a). OWASP Top 10 for Agentic Applications 2026. https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/
- OWASP. (2025b). Agentic AI - Threats and Mitigations v1.0.1. https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/
- OWASP. (2025c). OWASP Top 10 for LLM Applications 2025. https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/

5.3. Investigación académica

- Bui, T., et al. (2025). The dark side of LLMs: Agent-based attacks for complete computer takeover. arXiv:2507.06850. https://arxiv.org/abs/2507.06850
- Deng, G., et al. (2025). AI agents under threat: A survey of key security challenges and future pathways. ACM Computing Surveys, 57(7), 1-36. https://doi.org/10.1145/3716628
- Derczynski, L., et al. (2024). garak: A framework for security probing large language models. arXiv:2406.11036. https://arxiv.org/abs/2406.11036
- Masterman, T., et al. (2026). The 2025 AI Agent Index. arXiv:2602.17753. https://arxiv.org/abs/2602.17753
- Tian, Z., et al. (2026). Taming various privilege escalation in LLM-based agent systems. arXiv:2601.11893. https://arxiv.org/abs/2601.11893

5.4. Informes de industria

Cisco. (2025). AI Readiness Index 2025. https://www.cisco.com/c/m/en_us/solutions/ai/readiness-index/realizing-the-value-of-ai.html

Equixly. (2025). MCP servers: The new security nightmare. https://equixly.com/blog/2025/03/29/mcp-server-new-security-nightmare/

Lakera. (2025). GenAI Security Readiness Report 2025. https://www.lakera.ai/genai-security-report-2025

Rehberger, J. (2025). Persistent memory poisoning in ChatGPT. Embrace The Red Blog. https://embracethered.com/

Unit 42. (2025). Agentic AI threats. Palo Alto Networks. https://unit42.paloaltonetworks.com/agentic-ai-threats/

Willison, S. (2025). MCP prompt injection. https://simonwillison.net/2025/Apr/9/mcp-prompt-injection/

6. Objetivos Concretos e Interés de los Mismos

6.1.Objetivo global

Diseñar, desarrollar y validar ARGOS, un **framework de auditoría de seguridad para agentes IA** que integre una metodología sistemática con una herramienta software funcional, proporcionando el primer recurso unificado y práctico para auditar agentes IA en conformidad con los principales marcos regulatorios.

El proyecto **no está amparado en un proyecto de investigación formal ni forma parte de un proyecto empresarial**, si bien cuenta con la orientación directa del director del TFM desde su posición como CTO de Ciberseguridad en IBM Consulting, lo que garantiza alineamiento con necesidades reales de la industria.

6.2. Objetivos específicos

Cada objetivo tiene métricas verificables por el tribunal. El cumplimiento conjunto de OE1-OE6 logra el objetivo global al cubrir investigación (OE1), desarrollo (OE2-OE5) y validación (OE6):

6.2.1. OE1 - Metodología de auditoría ARGOS

Diseñar una metodología que integre OWASP ASI01-ASI10, CSA AICM y requisitos de EU AI Act, NIST AI RMF e ISO 42001.

- Cobertura del 100% de amenazas OWASP ASI con al menos 3 controles auditables por amenaza
- Mapeo formal a 4+ frameworks regulatorios
- Calibración por niveles de autonomía CSA (0-5)

6.2.2. OE2 - Escaneo de configuración

Implementar módulo de escaneo estático de configuraciones MCP.

- 15+ patrones de riesgo detectados (tool poisoning, command injection, permisos excesivos, credenciales, ausencia de TLS)
- Informe estructurado con severidad Crítica/Alta/Media/Baja

6.2.3. OE3 - Red teaming agéntico

Implementar módulo de red teaming con probes específicos para OWASP ASI.

- 20+ probes cubriendo las 10 categorías ASI01-ASI10
- Detectores configurables: string matching, regex, LLM-as-judge

6.2.4. OE4 - Proxy MCP de auditoría

Implementar proxy transparente JSON-RPC 2.0 para monitorizar la comunicación agente-herramienta.

- Intercepción del 100% de llamadas MCP (tools/list, invocations, responses)
- Trazas OpenTelemetry estándar
- Detección de 5+ patrones anómalos: mutación de tool definitions, PII, invocaciones fuera de alcance
- Latencia < 50 ms por petición

6.2.5. OE5 - Generación de informes de compliance

Implementar módulo de reporting mapeado a marcos regulatorios.

- 2 formatos: HTML interactivo + JSON/JSONL
- Mapeo a OWASP ASI, EU AI Act Anexo IV, NIST AI RMF

6.2.6. OE6 - Validación empírica

Validar ARGOS contra 3 escenarios reales de agentes IA.

- Escenario 1: Agente single ReAct con herramientas MCP
- Escenario 2: Sistema multi-agente supervisor-worker
- Escenario 3: Agente con memoria persistente
- Documentación de TP, FP, FN, cobertura y tiempo de ejecución

7. Declaración de lo que No se Contempla

Para garantizar un **MVP realista en el plazo abril-julio de 2026**, ARGOS delimita claramente su alcance:

Exclusión	Qué NO hacemos	Por qué
Bloqueo en runtime	ARGOS detecta y reporta, NO bloquea acciones en tiempo real	Requiere garantías de latencia <10 ms fuera del alcance de un TFM. Lo cubren NeuralTrust/Lakera Guard
Todos los frameworks de agentes	Sólo LangChain/LangGraph + protocolo MCP	Son la arquitectura dominante. Los plugins permiten extensión futura a CrewAI, AutoGen, etc.
Testing de modelos fundacionales	No auditamos GPT-4, Claude ni Llama como modelos	Ya lo cubren Garak y Promptfoo. ARGOS se centra en la capa agéntica
Certificación formal	Metodología de auditoría, NO programa de certificación	Requiere organismo acreditado y gobernanza institucional
Frontend web completo	CLI-first con salida HTML/JSON. Sin dashboard interactivo	Complejidad innecesaria para el núcleo de la investigación
Soporte multiidioma	Herramienta y documentación sólo en inglés	Estándar en herramientas de seguridad open-source
Despliegue cloud/SaaS	Ejecución 100% local, sin componentes cloud	Las organizaciones con datos sensibles no pueden enviar información a terceros

8. Requisitos de Usuario

ID	Requisito	Prioridad	Justificación
RU-01	Escanear la configuración de un agente con un único comando CLI	Alta	Barrera de entrada mínima. Patrón de Garak y Promptfoo
RU-02	Seleccionar categorías OWASP ASI a testear (ej. sólo ASI01, ASI06)	Alta	No todas las auditorías requieren cobertura completa
RU-03	Ejecutar el proxy MCP sin modificar el código del agente auditado	Alta	Principio fundamental de auditoría: no intrusividad
RU-04	Recibir un informe comprensible con severidad, evidencia y recomendaciones	Alta	Informes accionables. El EU AI Act Anexo IV exige documentación comprensible
RU-05	Definir reglas de auditoría personalizadas en YAML	Media	Cada organización tiene políticas distintas. Patrón Nuclei
RU-06	Mapear resultados a frameworks regulatorios específicos	Media	Evidencia de compliance específica por framework
RU-07	Integrar ARGOS en pipelines CI/CD mediante exit codes	Media	Seguridad shift-left en el ciclo de desarrollo
RU-08	Instalar mediante pip install en menos de 5 minutos	Alta	Crítico para la adopción open-source

9. Requisitos de Sistema

9.1.Requisitos funcionales

ID	Requisito funcional	Módulo	Prioridad
RF-01	Parsear configuraciones MCP (JSON) detectando patrones de riesgo	Escáner	Alta
RF-02	Detectar tool poisoning en descripciones de herramientas MCP	Escáner	Alta
RF-03	Detectar permisos excesivos en las definiciones de herramientas	Escáner	Alta
RF-04	Detectar credenciales hardcoded y secrets	Escáner	Alta
RF-05	Generar probes adversariales por categoría OWASP ASI01-ASI10	Red Team	Alta
RF-06	Evaluar respuestas con detectores configurables	Red Team	Alta
RF-07	Soportar probes multi-turno (ej. memory poisoning progresivo)	Red Team	Alta
RF-08	Interceptar tráfico JSON-RPC 2.0 MCP de forma transparente	Proxy	Alta
RF-09	Emitir trazas OpenTelemetry por cada invocación de herramienta	Proxy	Alta
RF-10	Detectar mutaciones en las definiciones de herramientas entre sesiones	Proxy	Alta
RF-11	Detectar PII y credenciales en las respuestas de herramientas	Proxy	Media
RF-12	Generar informes HTML con evidencia y recomendaciones	Informes	Alta
RF-13	Exportar resultados en JSONL	Informes	Media
RF-14	Mapear hallazgos a OWASP ASI + EU AI Act + NIST	Informes	Alta
RF-15	Soportar reglas YAML personalizadas	Núcleo	Media
RF-16	Cargar plugins dinámicamente desde directorios convencionados	Núcleo	Alta

9.2. Requisitos no funcionales

ID	Requisito	Justificación
RNF-01	Python 3.11+	Ecosistema ML/AI dominante (Garak, LangChain, Langfuse)
RNF-02	Latencia del proxy < 50 ms/petición	No degradar el rendimiento del agente auditado
RNF-03	pip install argos-ai-audit	Estándar Python para la adopción
RNF-04	Ejecución 100% local, sin cloud	RGPD y datos sensibles
RNF-05	AGPL-3.0 (Community) + licencia comercial (Enterprise)	Open-core: la comunidad usa gratis; las empresas que no quieran publicar compran licencia
RNF-06	Arquitectura extensible mediante plugins	Contribución comunitaria sin tocar el núcleo
RNF-07	Tests unitarios > 70% de cobertura	Fiabilidad y confianza en regresión
RNF-08	Documentación: README, API docs, guía de contribución	Imprescindible para la adopción open-source

9.3. Arquitectura técnica

ARGOS se organiza en 3 capas independientes y extensibles:

Capa	Componentes	Tecnologías	Patrón de referencia
1: Recolección	Config Scanner + MCP Audit Proxy + LangGraph Callback	Pydantic, asyncio, OpenTelemetry SDK	OWASP ZAP (proxy) + Langfuse (OTel)
2: Análisis	Probes (red team activo) + Detectores (pasivo) + Motor de reglas YAML	Python plugins, PyYAML, regex	Garak (probes/detectores) + Nuclei (plantillas YAML)
3: Informes	Informe HTML + Exportación JSONL + Mapeador de compliance	Jinja2, JSON, Pydantic	Nuclei reporters

Decisiones clave: Python 3.11+ (ecosistema), OpenTelemetry (estándar de la industria), plugins tipo Garak (descubrimiento por importlib), reglas YAML tipo Nuclei (contribución sin código), proxy MCP tipo ZAP (no intrusivo), SQLite local (sin dependencias), CLI con Typer (estándar en seguridad).

10. Plan de Trabajo

10.1. Desglose en fases y tareas

FASE 1: Investigación y Diseño (Sem. 1-3 | 7-27 de abril de 2026)

Tarea	Descripción	Entregable	Horas
T1.1 Análisis de frameworks	Análisis de CSA AICM (243 controles), OWASP ASI + Threats, NIST AI RMF, EU AI Act Anexos III-IV. Mapeo cruzado.	Matriz de mapeo en hoja de cálculo	25 h
T1.2 Diseño de la metodología	Controles de auditoría por amenaza ASI. Calibración por autonomía CSA (0-5). Diagramas de flujo.	Metodología ARGOS v1.0	20 h
T1.3 Diseño arquitectónico	Interfaces Python (ABC), modelos Pydantic, formato YAML de reglas, protocolo del proxy.	Diseño técnico + diagramas	15 h
T1.4 Configuración del proyecto	Repositorio GitHub, CI/CD (GitHub Actions), entorno, pyproject.toml.	Repositorio inicializado	5 h

FASE 2: Desarrollo del Núcleo (Sem. 4-7 | 28 de abril - 25 de mayo de 2026)

Tarea	Descripción	Entregable	Horas
T2.1 Motor central + CLI	Sistema de plugins, CLI con Typer, configuración YAML/JSON, modelos Pydantic.	argos --help funcional	20 h
T2.2 Escáner de configuración	Parser de MCP JSON. 15+ reglas: tool poisoning, cmd injection, permisos, credenciales, TLS.	argos scan config.json	25 h
T2.3 Proxy MCP	Servidor async JSON-RPC 2.0, intercepción, reenvío, trazas OTel, detección de mutaciones.	argos proxy funcional	30 h
T2.4 Motor de reglas YAML	Parser YAML, matchers, extractores, metadatos (severidad, referencia OWASP).	Reglas YAML ejecutables	15 h

FASE 3: Red Teaming y Detección (Sem. 8-10 | 26 de mayo - 15 de junio de 2026)

Tarea	Descripción	Entregable	Horas
T3.1 Probes ASI	20+ probes: goal hijack, tool misuse, escalada de privilegios, cadena de suministro, ejecución de código, envenenamiento de memoria, inter-agent, cascada, confianza, agentes descontrolados.	Biblioteca de probes ejecutable	30 h
T3.2 Detectores	StringMatch, Regex, LLMJudge, BehaviorDetector. Umbrales configurables.	Suite de detectores	20 h
T3.3 Integración con LangGraph	Callback handler OTel. Testing con agentes ReAct y Supervisor.	Integración funcional	15 h

FASE 4: Informes y Validación (Sem. 11-13 | 16 de junio - 6 de julio de 2026)

Tarea	Descripción	Entregable	Horas
T4.1 Motor de informes	Plantillas Jinja2 HTML. Exportador JSONL. Mapeador de compliance multi-framework.	argos report funcional	20 h
T4.2 Validación	3 escenarios: single ReAct + MCP, multi-agente supervisor, agente con memoria. Métricas TP/FP/FN.	Informe de validación	25 h
T4.3 Documentación	README, API docs (MkDocs), CONTRIBUTING.md, publicación en PyPI.	Paquete publicado	15 h

FASE 5: Redacción y Defensa (en paralelo con las Fases 3-4)

Tarea	Descripción	Entregable	Horas
T5.1 Memoria del TFM	Capítulos: Introducción, Estado del Arte, Metodología, Arquitectura, Validación, Conclusiones.	Memoria completa	40 h
T5.2 Defensa	Presentación de 15-20 diapositivas, demo en vivo, ensayo.	Presentación lista	10 h

Total estimado: 330 horas (25 h/semana durante 13 semanas)

10.2. Cronograma

Semana	Fechas	Fase	Tareas	Hito
1-2	7-20 de abril	FASE 1	T1.1, T1.2	
3	21-27 de abril	FASE 1	T1.2, T1.3, T1.4	H1: Metodología + Diseño
4-5	28 abr. - 11 may.	FASE 2	T2.1, T2.2, T2.3	
6-7	12-25 de mayo	FASE 2	T2.2, T2.3, T2.4	H2: MVP funcional
8-9	26 may. - 8 jun.	FASE 3	T3.1, T3.2	
10	9-15 de junio	FASE 3	T3.1, T3.2, T3.3	H3: Red Teaming completo
11-12	16-29 de junio	FASE 4+5	T4.1, T4.2, T5.1	H4: Validación + Informes
13	30 jun. - 6 jul.	FASE 4+5	T4.3, T5.1, T5.2	H5: Entrega final

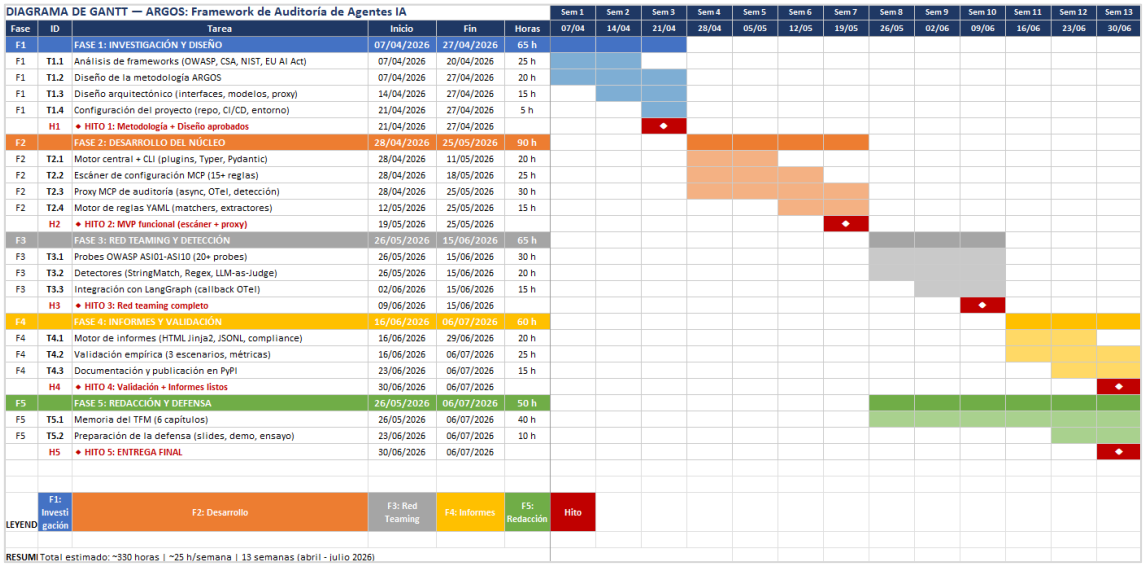

Ilustración 1. Diagrama de Gantt Organización de Proyecto

11. Beneficios del Proyecto

11.1. Nuevos servicios posibles

- **Auditoría de agentes IA:** Las consultoras de ciberseguridad pueden usar ARGOS como base para ofrecer servicios de auditoría de agentes IA.
- **Compliance-as-a-Service:** Con las obligaciones del EU AI Act entrando en vigor en agosto de 2026, ARGOS proporciona la base técnica para la verificación de conformidad.
- **Evaluación de seguridad de proveedores MCP:** Evaluar la seguridad de servidores MCP de terceros antes de integrarlos.

11.2. Mejora respecto al modo actual

Sin ARGOS	Con ARGOS
Auditoría manual de configuraciones, propensa a errores	Escaneo automatizado con 15+ reglas en segundos
Sin visibilidad de las comunicaciones MCP en producción	Proxy con trazas OTel y detección de anomalías
Red teaming genérico que no cubre agentes	Red teaming específico OWASP ASI01-ASI10
Compliance manual con hojas de cálculo	Informes automatizados multi-framework
Sólo herramientas comerciales (>50.000 EUR/año)	Alternativa open-core accesible

11.3. Explotación de resultados

11.3.1. Modelo de negocio: Open-Core

ARGOS seguirá un modelo **open-core** (el mismo de MongoDB, Grafana, Elastic y NeuralTrust):

Componente	Community (AGPL-3.0)	Enterprise (comercial)
Motor central + CLI + sistema de plugins	Incluido	Incluido
Escáner de configuración (10 reglas básicas)	Incluido	Incluido
8 probes básicos (demostración)	Incluido	Incluido
Formato YAML de reglas (especificación)	Incluido	Incluido
Proxy MCP completo + detección avanzada	-	Incluido
Biblioteca de 20+ probes ASI01-ASI10	-	Incluido
Detector LLM-as-Judge	-	Incluido
Mapeador de compliance multi-framework	-	Incluido
Informes enterprise	-	Incluido
Actualizaciones continuas de reglas	-	Suscripción
Soporte + SLA	-	Contrato

Precio de referencia del mercado (basado en competidores reales):

Segmento	Precio/año	Referencia
Startup / PYME	5.000-15.000 EUR	NeuralTrust tier básico
Mid-market	25.000-60.000 EUR	HiddenLayer, Lasso Security
Enterprise	80.000-200.000+ EUR	Palo Alto AIRS, IBM Guardium
Consultoría puntual	8.000-30.000 EUR/auditoría	Mercado español de pentest IA

11.3.2. Propiedad intelectual

La propiedad intelectual del software desarrollado permanece con el autor. La Universidad Europea recibe una licencia académica no exclusiva para uso interno y referencia en publicaciones institucionales. El autor se reserva todos los derechos de explotación comercial.

En Madrid, a 22 de Abril de 2026,

Propone	Acepta
54347448N DIEGO RODRÍGUEZ (R: E22754246) Firmado digitalmente por 54347448N DIEGO RODRÍGUEZ (R: E22754246) Fecha: 2026.04.05 23:42:25 +02'00'	
Fdo. Alumno: D. Diego Rodríguez Sanz	Fdo. Profesor Tutor: D. José Cándido Carballido López

La propuesta, una vez aceptada y firmada por el director del proyecto, se subirá al campus virtual y se remitirá por correo al Director del Máster.